

Security Assessment Results and Analysis

Finding 1: OWASP Juice Shop Welcome Page

Finding : Successful Application Initialization

Category: Environment Setup

Severity: Informational

Description:

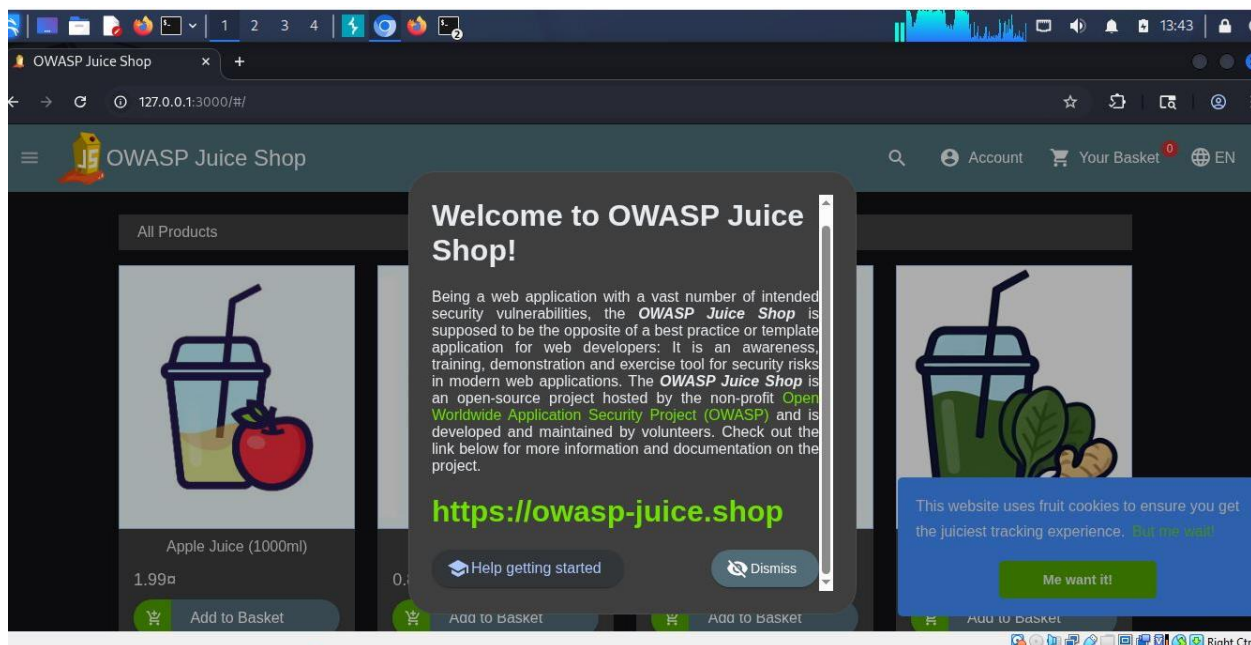
The screenshot shows the OWASP Juice Shop welcome page after the application was successfully launched in the Docker-based testing environment. The welcome message confirms that the application is running correctly and is ready for security testing activities, including network scanning, vulnerability assessment, and HTTP traffic analysis.

Impact:

A successfully initialized application ensures that all security assessment tools can interact with the target without deployment issues. It provides a stable environment for identifying vulnerabilities and evaluating the application's security posture.

Recommendation:

No remediation required. Maintain an isolated testing environment for future security assessments.



Snapshot 1: OWASP Juice Shop Welcome Page Confirming Successful Application Deployment

Finding 2: Nmap Network Scan Results

Finding : Open TCP Port 3000 Detected

Category: Network Exposure

Severity: Low

Description:

The Nmap scan identified TCP Port 3000 as open, confirming that the OWASP Juice Shop application was actively listening for HTTP connections. This indicates that the web application is reachable over the network and available for user access.

Impact:

An exposed network service increases the application's attack surface. If the service is accessible from untrusted networks, attackers may attempt port scanning, service enumeration, or exploit vulnerabilities associated with the exposed application.

Remediation:

Restrict network access by implementing firewall rules, limiting access to trusted hosts, or placing the application behind a reverse proxy or network segmentation. Regularly review exposed ports and disable services that are not required.

```

kali@kali: ~
Session Actions Edit View Help

(kali@kali)~$ ss -tln
Netid      State      Recv-Q     Send-Q     Local Address:Port      Peer Address:Port
tcp        LISTEN     0           4096       127.0.0.1:41421          0.0.0.0:*
tcp        LISTEN     0           4096       0.0.0.0:3000            0.0.0.0:*
tcp        LISTEN     0           4096       [::]:3000                [::]:*

(kali@kali)~$ nmap -Pn localhost
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-02 11:56 -0400
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000029s latency).
Other addresses for localhost (not scanned): ::1
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE
3000/tcp  open  ppp

Nmap done: 1 IP address (1 host up) scanned in 0.24 seconds

(kali@kali)~$ nmap -Pn -sV -p 3000 localhost
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-02 11:57 -0400
Nmap scan report for localhost (127.0.0.1)
Host is up (0.00016s latency).
Other addresses for localhost (not scanned): ::1
PORT      STATE SERVICE VERSION
3000/tcp  open  ppp?
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-ser
vice :
SF-Port3000-TCP:V=7.99I=7%D=8/2%Time=6A6F6911P=x86_64-pc-linux-gnu%r(Get
SF:Request,2866,"HTTP/1.1\x20200K\r\nAccess-Control-Allow-Origin:\x2
SF:0*\r\nX-Content-Type-Options:\x20nosniff\r\nX-Frame-Options:\x20SAMEOR

```

Snapshot 2: Nmap Scan Result Showing Open TCP Port 3000

Finding 3: Nikto Vulnerability Scan Results

Finding : Missing HTTP Security Headers

Category: Security Misconfiguration

Severity: Medium

Description:

The Nikto vulnerability scan identified several missing HTTP security headers, including Content Security Policy (CSP), Strict-Transport-Security (HSTS), and Referrer-Policy. These missing security controls may leave the application more vulnerable to web-based attacks and information disclosure.

Impact:

The absence of security headers can increase the risk of attacks such as Cross-Site Scripting (XSS), man-in-the-middle (MITM) attacks, and unintended disclosure of sensitive information. These weaknesses reduce the overall security posture of the application.

Remediation:

Configure all recommended HTTP security headers according to security best practices. Regularly perform vulnerability scans to verify that security configurations remain effective after application updates or configuration changes.

```
(kali@kali)-[~]
$ nikto -h http://localhost:3000
- Nikto v2.6.0

+ Target IP: 127.0.0.1
+ Target Hostname: localhost
+ Target Port: 3000
+ Platform: Unknown
+ Start Time: 2026-08-02 12:50:35 (GMT-4)

+ Server: No banner retrieved
+ ERROR: Failed to check for updates: 403
+ [999986] /: Retrieved access-control-allow-origin header: *.
+ [999100] /: Uncommon header(s) 'x-recruiting' found, with contents: /#/jobs.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [999996] /robots.txt: contains 1 entry which should be manually viewed. See: https://developer.mozilla.org/en-US/docs/Glossary/Robots.txt
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [001675] /ftp/: This might be interesting.
+ [001811] /public/: This might be interesting.
+ [002730] /httpswd: Contains authorization information.
+ [002743] /bash_history: A user's home directory may be set to the web root, the shell history was retrieved. This should not be accessible via the web.
+ [002756] /sh_history: A user's home directory may be set to the web root, the shell history was retrieved. This should not be accessible via the web.
+ ERROR: ** Error limit (20) reached for host, giving up. Last error: error reading HTTP response. **
+ ERROR: ** Consider using mitmproxy to avoid TLS fingerprinting. **
- STATUS: Completed 6427 requests (~89% complete, ~47 seconds left): currently in plugin 'Nikto Tests'
- STATUS: Running average: Not enough data.
+ Scan terminated: 20 errors and 12 items reported on the remote host
+ End Time: 2026-08-02 12:56:53 (GMT-4) (378 seconds)

+ 1 host(s) tested
```

Snapshot 3: Nikto Scan Result Identifying Missing HTTP Security Headers

Finding 4: User Interaction with OWASP Juice Shop

Finding : Successful User Activity Captured for HTTP Traffic Analysis

Category: HTTP Traffic Analysis

Severity: Informational

Description:

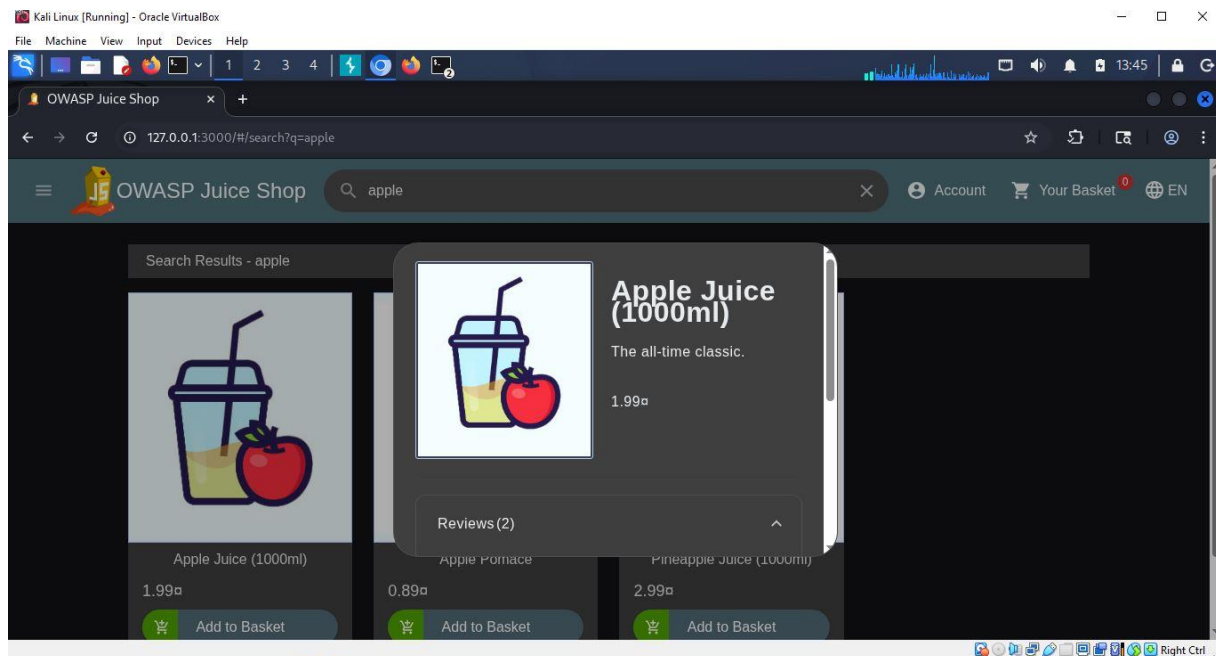
After successfully logging into the OWASP Juice Shop application, the user searched for the Apple Juice product and explored its details. These interactions generated multiple HTTP requests and responses, which were successfully captured in Burp Suite HTTP History. This confirmed that Burp Suite was correctly intercepting and recording the application's network traffic for further security analysis.

Impact:

Capturing user interactions allows security analysts to examine how the application communicates with the server, identify exposed parameters, review request and response headers, and detect potential security weaknesses during normal application usage.

Recommendation:

Continue monitoring authenticated HTTP traffic during testing and ensure that all sensitive communications are protected using HTTPS. Regularly review captured requests to identify insecure data transmission, authentication issues, or other potential vulnerabilities.



Snapshot 4: Product Search and User Interaction Used for HTTP Traffic Analysis

Finding 5: Burp Suite HTTP Traffic Analysis

Finding : HTTP Request and Response Inspection

Category: Traffic Analysis

Severity: Informational

Description:

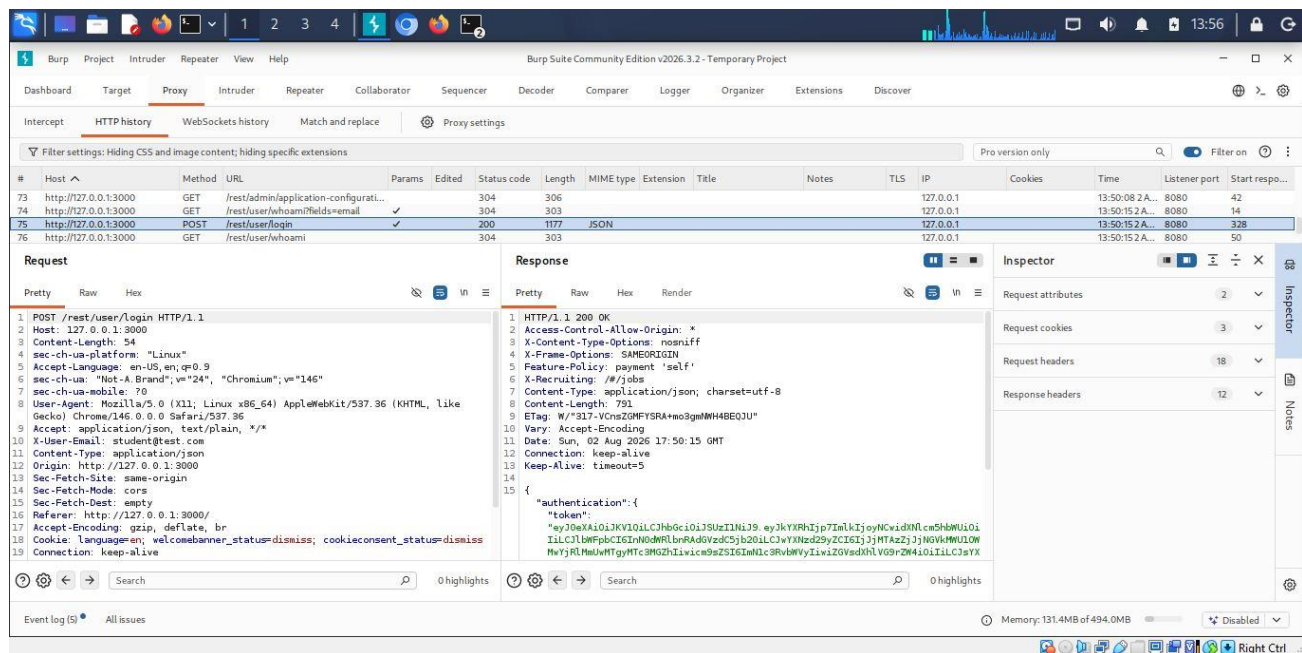
Burp Suite successfully intercepted and analyzed HTTP requests and responses exchanged between the client and the OWASP Juice Shop application. This process allowed detailed examination of user interactions, request parameters, response headers, and application behavior.

Impact:

Traffic analysis helps identify insecure communication, exposed sensitive information, insecure session handling, and potential application vulnerabilities that may not be visible through automated scanning alone.

Remediation:

Encrypt all communications using HTTPS, validate request and response data, and periodically analyze application traffic to identify potential security weaknesses before deployment.



Snapshot 5: Burp Suite Capturing HTTP Requests and Responses